

Lecture 26 : Basic concepts of cryptography

Introduction

In today's interconnected world, the concept of "hacking" or "breaking into a system" is a pervasive threat. At its core, hacking involves identifying vulnerabilities or weaknesses within an existing system, network, or organizational infrastructure to gain unauthorized access or cause disruption. While it's impossible to eliminate the risk of such attacks entirely, various techniques are employed to strengthen infrastructure and minimize these threats. Cryptography stands out as one of the most crucial and effective tools in this defense arsenal.

This lecture introduces the fundamental concepts of cryptography, providing a foundational understanding of how network-based attacks occur and how cryptographic techniques can be leveraged to prevent them. We will explore generic security attacks, the essential security services that systems aim to provide, and the cryptographic primitives that underpin these services. By grasping these basics, we can better appreciate the complexities of cybersecurity and the vital role cryptography plays in safeguarding our digital information and communications.

Core Concepts

Term	Definition	Significance
Hacking	Identifying and exploiting vulnerabilities in a system or network to gain unauthorized access or cause harm.	Represents the primary threat that cybersecurity measures, including cryptography, aim to mitigate.
Cryptography	The practice and study of techniques for secure communication in the presence of adversarial behavior.	Provides essential tools and methods to protect information and ensure secure digital interactions.
Security Attack	Any action that compromises the security of information, whether in a	Categorizes malicious activities that target information systems, leading

Term	Definition	Significance
	computer, network, or during flow.	to various forms of compromise.
Interruption	An attack on availability where an intruder prevents legitimate users from accessing a service or resource.	Directly impacts the ability of users to utilize services, often leading to denial of service.
Interception	An attack on confidentiality where an unauthorized party gains access to information during transmission.	Compromises the privacy of data, allowing sensitive information to be read by unintended recipients.
Modification	An attack on integrity where an intruder alters transmitted data before it reaches its destination.	Undermines the trustworthiness of information, potentially leading to incorrect decisions or catastrophic outcomes.
Fabrication	An attack on authenticity where an intruder generates false data or messages, pretending to be a legitimate source.	Deceives recipients into believing false information originated from a trusted source, compromising trust.
Passive Attack	An attack where an intruder monitors or collects information without altering system resources or data.	Difficult to detect as it leaves no trace, primarily targeting confidentiality through eavesdropping or traffic analysis.
Active Attack	An attack where an intruder modifies data, injects false data, or disrupts services.	Easier to detect due to changes in system state or data, targeting integrity, authenticity, and availability.
Confidentiality		Protects sensitive data from unauthorized disclosure,

Term	Definition	Significance
	Ensuring that information is accessible only to those authorized to have access.	crucial for privacy and competitive advantage.
Authentication	Verifying the identity of a user, system, or the origin of data.	Confirms that a party or message is genuinely who or what it claims to be, preventing masquerading.
Integrity	Maintaining the accuracy and completeness of data, preventing unauthorized modification.	Guarantees that data has not been altered or corrupted, ensuring its reliability and trustworthiness.
Non-repudiation	Preventing a party from denying an action or communication they performed.	Provides undeniable proof of origin or receipt, essential for legal and transactional accountability.
Availability	Ensuring that authorized users have timely and uninterrupted access to information and resources.	Guarantees continuous operation of services, preventing disruptions like denial of service attacks.
Encryption	The process of transforming information into a secure, unreadable format (ciphertext) to protect it.	A fundamental cryptographic primitive for achieving confidentiality, making data unintelligible to unauthorized parties.

Detailed Analysis

1. Understanding Security Attacks

A security attack is broadly defined as any action that compromises the security of information, whether it resides on a computer, flows through a network, or is part of an organizational infrastructure. These attacks exploit vulnerabilities, which can range from software bugs to weak configurations, to achieve malicious objectives.

- **Four Primary Types of Security Attacks:**

- **Interruption:** This attack targets the availability of a system or service.
- **Mechanism:** An intruder prevents a message from reaching its intended destination. For instance, by hacking a router, an attacker can redirect or discard packets, effectively stopping communication.
- **Example:** A Denial of Service (DoS) attack, where legitimate users are unable to access a web server or mail server because the communication is blocked or overwhelmed.
- **Impact:** Loss of access to critical services, disrupting operations.
- **Interception:** This attack targets the confidentiality of information.
- **Mechanism:** An intruder silently listens to communications between a source and a destination, gaining unauthorized access to the data. While physically tapping cables is difficult, hacking a router to copy packets to an intruder's machine is a common method.
- **Example:** An attacker reading confidential bank account details or personal messages as they are transmitted across a network.
- **Impact:** Disclosure of sensitive information to unauthorized parties.
- **Modification:** This attack targets the integrity of information.
- **Mechanism:** An intruder not only intercepts a message but also alters its content before forwarding it to the destination. This requires more intelligence than simple interception, as the attacker might also need to update related fields, like checksums in IP packets, to avoid detection.
- **Example:** During a military operation, an enemy hacking into communication channels to change strategic messages, leading to catastrophic decisions.
- **Impact:** Corruption of data, leading to false information and potentially severe consequences.
- **Fabrication:** This attack targets the authenticity of information.
- **Mechanism:** An intruder creates and injects false messages into the network, impersonating a legitimate source. The destination receives the fabricated packet and believes it originated from the genuine sender.
- **Example:** An attacker sending an email pretending to be a bank, asking for personal details, or sending a malicious command disguised as coming from an authorized administrator.
- **Impact:** Deception, leading to unauthorized actions or spread of misinformation.
- **Classification by Nature: Passive vs. Active Attacks:**
- **Passive Attacks:**

- **Nature:** The intruder observes or collects information without altering the network or the data flowing through it. This is often referred to as "eavesdropping."
- **Detection:** Extremely difficult to detect because no changes are made to the system, making it hard for users to realize something is wrong.
- **Types:**
 - **Message Content Reading:** Simply reading confidential messages.
 - **Traffic Analysis:** Analyzing patterns of communication (e.g., who communicates with whom, frequency, volume) to infer sensitive information or identify critical nodes in a network. This can help an attacker pinpoint the most valuable targets for future active attacks.
 - **Security Property Attacked:** Primarily confidentiality.
- **Active Attacks:**
 - **Nature:** The intruder actively modifies data, injects false data, or disrupts services. These attacks involve some form of change to the network's state or data.
 - **Detection:** Generally easier to detect than passive attacks because they leave traces or cause noticeable disruptions.
 - **Types:**
 - **Masquerade:** One entity pretends to be another (e.g., an attacker sending a message claiming to be a legitimate user).
 - **Replay:** An intruder captures a legitimate sequence of data or authentication credentials and retransmits them later to gain unauthorized access or perform an action.
 - **Modification:** As discussed above, altering parts of a message in transit. This often requires updating other fields like checksums to avoid immediate detection.
 - **Denial of Service (DoS):** Preventing legitimate users from accessing a service or resource, often by overwhelming it or disrupting its communication path.
 - **Security Properties Attacked:** Integrity, authenticity, and availability.

2. Essential Security Services

Based on the types of attacks, several desirable security services have been identified. The necessity of each service varies depending on the specific organization and the nature of the services it provides.

- **Confidentiality:**

- **Purpose:** Ensures that information is kept private and is not disclosed to unauthorized individuals.
- **Example:** Protecting user IDs and passwords during bank logins or online transactions.
- **Relevance:** Crucial for privacy and protecting sensitive business or personal data.
- **Authentication:**
 - **Purpose:** Verifies the identity of a user, system, or the origin of a message.
 - **Example:** Using One-Time Passwords (OTPs) or multi-factor authentication for banking transactions to confirm the user's identity.
 - **Relevance:** Prevents impersonation and ensures that interactions are with legitimate entities.
- **Integrity:**
 - **Purpose:** Guarantees that data has not been altered or corrupted during storage or transmission.
 - **Example:** Ensuring that an important document or financial transaction record remains exactly as it was originally created, without unauthorized changes.
 - **Relevance:** Maintains the trustworthiness and reliability of information.
- **Non-repudiation:**
 - **Purpose:** Provides undeniable proof that a sender sent a message and a receiver received it, preventing either party from falsely denying their involvement.
 - **Example:** A digital signature on a contract, making it impossible for the signer to later claim they did not sign it.
 - **Relevance:** Essential for legal accountability and establishing trust in digital transactions.
- **Access Control:**
 - **Purpose:** Regulates who can access specific resources or perform certain actions within a system.
 - **Example:** Defining how much computing power or memory a user is allowed to utilize in a cloud service.
 - **Relevance:** Manages permissions and prevents unauthorized use of resources.
- **Availability:**
 - **Purpose:** Ensures that systems and services are accessible and operational when needed by authorized users.

- **Example:** The expectation that services like Gmail are always accessible, and a sudden outage would cause significant disruption.
- **Relevance:** Guarantees continuous service delivery and prevents denial of service scenarios.

3. Cryptographic Primitives for Security

Cryptography provides the fundamental tools and techniques to achieve these security services. The core idea is to transform information in such a way that only authorized parties can understand or verify it.

- **Encryption and Decryption:**
 - **Encryption:** The process of "garbling" a message (plaintext) into an unreadable format (ciphertext) using a secret key. This ensures that if an unauthorized person intercepts the message, they cannot make sense of it.
 - **Decryption:** The reverse process, transforming the ciphertext back into readable plaintext using a key. Only the intended recipient, possessing the correct key, should be able to decrypt the message.
 - **Role:** These are the most fundamental cryptographic primitives, primarily providing confidentiality.
- **Types of Encryption Schemes:**
 - **Private Key (Symmetric) Encryption:**
 - **Mechanism:** Both the sender and the receiver use the same secret key for both encryption and decryption. This key must be shared securely between the communicating parties.
 - **Process:** Sender encrypts message with the shared private key; receiver decrypts with the same private key.
 - **Challenge:** Securely sharing the secret key initially is a critical problem.
 - **Public Key (Asymmetric) Encryption:**
 - **Mechanism:** Each participant has a pair of keys: a public key (known to everyone) and a private key (kept secret by the owner).
 - **Process:** If Alice wants to send a message to Bob, she encrypts it using Bob's public key. Only Bob can decrypt it using his corresponding private key. Conversely, if Bob wants to prove his identity, he can encrypt something with his private key, and anyone can verify it using his public key.
 - **Advantage:** Eliminates the need for a pre-shared secret key for secure communication, as anyone can use the public key to send encrypted messages.

- **The Intruder's Model and Cryptanalysis:**

- In a cryptographic system, the intruder is assumed to be able to tap into the communication channel and obtain the encrypted information.

- **Cryptanalysis:** The intruder's attempt to decode the encrypted information without the correct key to obtain meaningful plaintext. This is designed to be extremely difficult, requiring immense computational power or sophisticated mathematical attacks.

- **Authentication Techniques:**

- Authentication is a critical primitive used in many security applications to verify the uniqueness and identity of the sender.

- **Methods:**

- **Encryption Techniques:** Can be used to prove identity by demonstrating knowledge of a secret key.

- **Cryptographic Hash Functions:** These functions take an input (e.g., a message) and produce a fixed-size string of characters (a hash value). Even a tiny change in the input results in a drastically different hash, making them useful for verifying data integrity and as part of authentication schemes.

- **Digital Signatures:** A cryptographic mechanism that allows the sender to digitally "sign" a message, providing authenticity, integrity, and non-repudiation. It uses the sender's private key, and the signature can be verified using their public key.

This lecture lays the groundwork for understanding how these cryptographic tools are applied to build robust security applications that protect networks and information from a wide array of attacks.

Key Takeaways

- [] Hacking exploits vulnerabilities in systems, networks, or infrastructure.
- [] Cryptography is a fundamental tool for preventing and mitigating cyberattacks.
- [] Security attacks can be broadly categorized into Interruption (availability), Interception (confidentiality), Modification (integrity), and Fabrication (authenticity).
- [] Attacks can also be classified as Passive (eavesdropping, traffic analysis, difficult to detect) or Active (masquerade, replay, modification, denial of service, easier to detect).

- [] Essential security services include Confidentiality, Authentication, Integrity, Non-repudiation, Access Control, and Availability.
- [] Encryption and Decryption are core cryptographic primitives for securing information.
- [] Private Key (Symmetric) encryption uses a single shared secret key for both encryption and decryption.
- [] Public Key (Asymmetric) encryption uses a pair of keys: a public key for encryption and a private key for decryption.
- [] Cryptanalysis is the process by which an intruder attempts to break encrypted messages without the key.
- [] Authentication can be achieved using encryption, cryptographic hash functions, and digital signatures.

Conclusion

This lecture has provided a crucial introduction to the landscape of cybersecurity, detailing the various forms of attacks that threaten our digital infrastructure and the essential security services required to counter them. From the silent threat of passive eavesdropping to the disruptive force of denial-of-service attacks, understanding these vulnerabilities is the first step toward building resilient systems. Cryptography emerges as the cornerstone of defense, offering powerful primitives like encryption and decryption, along with advanced techniques such as cryptographic hash functions and digital signatures.

By grasping the distinctions between symmetric and asymmetric key encryption, and recognizing how these tools address core security properties like confidentiality, integrity, and authenticity, we begin to appreciate the intricate mechanisms that safeguard our online interactions. The concepts discussed here form the bedrock for more advanced topics in network security, paving the way for future explorations into how these cryptographic principles are practically implemented to secure networks and protect sensitive information in an increasingly complex digital world.